

Purpose:

Cybersecurity Risk Acceptance is a deliberate executive decision by a business/Developer owner to acknowledge and accept a cybersecurity risk, which for the reason given cannot be remediated through available security controls and measures. The decision to accept cybersecurity risks should be made in consultation with other stakeholders, including Information Technology and Cybersecurity.

Risk acceptance is appropriate when further remediation or mitigation of the cybersecurity risk is not possible or is too costly, and the institutional benefit of the system, application or service exceeds the potential impact of the risk.

Cybersecurity risks include applications, services or systems or other vulnerability determined to:

- be a financial, reputational and/or personal privacy loss risk
- impair the functions of the Business
- present a legal liability
- include high and/or critical cybersecurity vulnerabilities according to the NIST Common Vulnerability Scoring System (CVSS)

Procedure:

1. Using the form that follows, the application/service/system owner describes the risk to be accepted and its potential impact, why it should be accepted, and mitigating factors, if any. The unit and person responsible for performing any mitigation should be specified. IT should be consulted on the description of the risk and mitigations so that they are suitably articulated in the description.
2. The completed form should be sent to the relevant business owner with executive responsibility for their review and signature. The business owner can choose to accept the described risk for up to one year, limit the acceptance to a shorter period, or deny the acceptance.
3. The form should then be sent to the CIO or equivalent for their acknowledgement signature and comments, if any.
4. The form should next be sent to sec-tsi@work.brins.co.id for review by the Cybersecurity Team for final approval. The risk acceptance Requestor will be notified of the outcome and a copy of the completed form.
5. If required, a new request can be submitted to extend a prior acceptance that will expire.
6. If acceptance of the risk is denied, the application, service or system must promptly be brought offline and/or terminated.

Cybersecurity Risk Acceptance Form

Name of Requestor: Click or tap here to enter text.
(Application, Service or System Operational Owner)

Asset Name: Click or tap here to enter text.

Department: Click or tap here to enter text.

☐ Check here if this risk has been accepted previously.

Description of Risk and/or Compliance Deviation: Click or tap here to enter text.

Benefit and Justification for Accepting this Risk: Click or tap here to enter text.

Factors that Minimize this Risk / Proposed Mitigation Plan: Click or tap here to enter text.

Business Owner Acceptance

I am the identified business owner and I: (a) understand the risks documented on this form; (b) acknowledge and accept this exception to policies, standards, guidelines and practices; (c) attest that the business or development need outweighs the identified risks of continued deployment and use of this system, application, or service; and (d) understand that this exception may be revoked if the level of associated risk increases.

- ☐ **Yes, for a temporary period:** Risk will be remediated by: Click or tap to enter a date.
(Max One Year)
- ☐ **Yes, for up to one year. Risk acceptance must be recertified annually.**
- ☐ **No.** I find the risk greater than the potential business benefit. This risk acceptance request is denied.

Requestor:

<i>Name (print)</i>	<i>Email/Telephone</i>
<i>Signature</i>	<i>Date</i>

CIO (or equivalent) Acknowledgement:

Comments (if any): Click or tap here to enter text.	
<i>Name:</i>	
<i>Signature</i>	<i>Date</i>

CIS:

☐ Approved	☐ Denied - Reason: Click or tap here to enter text.
☐ Approved with conditions / comments: Click or tap here to enter text.	
CIO, Chief Risk Officer, Chief Information Security Officer, or designee:	
<i>Name:</i>	
<i>Signature</i>	<i>Date</i>